

**What if a hacker gets inside your network... should
your services trust each other automatically?
Modern systems don't. Welcome to Zero-Trust
Security.**



What is Zero-Trust Security?



- Never trust, always verify
- Every user, device, and service must authenticate
- Trust is continuously validated
- Reduces security risks inside networks



Why Traditional Security Isn't Enough?



- Network perimeter is no longer enough
- Internal services can also be compromised
- Insider threats are real
- Cloud-native systems require stronger security



What is mTLS (Mutual TLS)?



- Both client and server authenticate each other
- Uses digital certificates for identity verification
- Encrypts all communication
- Prevents unauthorized service-to-service access



What are Global Identity Providers (IdPs)?



- Centralized identity management
- Single Sign-On (SSO)
- Supports OAuth 2.0, OpenID Connect (OIDC), and SAML
- Examples: Keycloak, Auth0, Okta, Microsoft Entra ID



Zero-Trust Authentication Flow



- User logs in through Identity Provider
- Identity Provider issues an access token
- API Gateway validates the token
- Services verify every request
- mTLS secures service-to-service communication



Benefits



- Stronger security
- Centralized authentication
- Secure microservice communication
- Easier compliance and auditing
- Better scalability for enterprise systems



Common Mistakes



- Trusting internal network by default
- Using shared credentials between services
- Missing certificate rotation
- Ignoring token expiration and validation
- Skipping least-privilege access

